The Economics of Cybersecurity

Why Cybersecurity Is Hard

Lecture 1: An economic perspective

Dana Etgar-Itzhaki
Sample lecture

© 2026 Dana Etgar Itzhaki. All rights reserved. These slides may be used for personal study only and may not be reproduced, distributed, or modified without the author's written permission.

A puzzle

- We have strong cryptography, firewalls, intrusion detection, and decades of security research.
- Yet breaches, ransomware, and large-scale outages keep growing in number and in cost.

> *If the technology exists, why is the world not more secure?*

- Anderson (2001): many security failures are economic, not technical.
- Security fails when the people who could prevent a failure are not the people who pay for it.

Where this course is going

Part I

Why it is hard

Externalities, incentives, hidden information, measurement

Part II

Canonical models

Optimal investment, security as a public good, interdependent security, vulnerability markets

Part III

Empirical research

Measuring the cost of attacks, ransomware, bug bounty platforms, systemic risk

Today: four economic reasons why security markets fail.

Four reasons

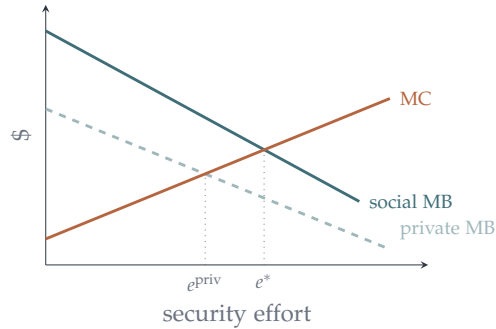
1. **Externalities**: my insecurity harms others, and I do not pay for it.
2. **Misaligned incentives**: those who can fix the problem do not bear its cost.
3. **Asymmetric information**: buyers cannot tell secure products from insecure ones.
4. **Measurement**: risks and damages are hidden, unreported, and hard to quantify.

Each one is a standard idea in economics. Cybersecurity is a setting in which all four operate at once.

1. Externalities: the infected computer

- An unprotected home computer is taken over and joins a **botnet**.
- The botnet is used to attack a third party, for example by flooding its servers (DDoS).
- The owner bears almost none of the damage, so the owner's incentive to protect is too weak.

Anderson and Moore (2006) point to this as a textbook negative externality.



Private marginal benefit lies below social marginal benefit, so equilibrium effort is below the social optimum.

Externalities in software markets

- Software markets have strong **network effects**: the more users a platform has, the more valuable it becomes.
- In such markets, being first matters more than being secure.
- Firms rationally ship early and fix security later, through patches.
- The cost of the vulnerabilities in the meantime falls largely on users, not on the vendor.

Discussion: is this a market failure, or a rational trade-off that users accept?

Anderson (2001).

2. Misaligned incentives: who bears the cost?

A classic example: ATM fraud in the U.S. and the U.K.

- In the U.S., banks bore the liability for disputed ATM transactions.
- In the U.K., the burden fell largely on customers: if the bank said its system was secure, the customer had to prove otherwise.
- Anderson (2001) argues that U.K. banks, protected from liability, invested less carefully in security, and suffered more fraud.

The economic principle

Liability should rest with the party best able to manage the risk. When it does not, we expect moral hazard and underinvestment.

3. Asymmetric information: a market for lemons

- Buyers cannot observe how secure a product is. Vendors can, at least in part.
- Buyers are therefore willing to pay only for *average* security.
- Vendors who invest in security cannot recover the cost, and secure products are driven out.
- This is Akerlof's (1970) market for lemons, applied to security.

Possible remedies

- Certification and standards
- Reputation and disclosure rules
- Liability for vendors
- Insurance that prices risk

Anderson (2001); Anderson and Moore (2006).

Attackers and defenders are not symmetric

- A defender must protect **every** point of entry. An attacker needs to find **one**.
- Security therefore often depends on the weakest link in a system.
- Information is also asymmetric between the two sides: attackers choose when, where, and how to strike; defenders often learn of an attack only after it has happened.

Next lecture: how the structure of a system (weakest link, total effort, best shot) changes the incentives to invest.

4. Measurement: what does an attack cost?

Why it is hard to measure

- Firms have incentives *not* to report attacks.
- Many costs are indirect: lost customers, reputation, disruption.
- Defense spending is a cost even when no attack occurs.

Components of cost

- Direct losses
- Indirect losses
- Costs of defense

Anderson et al. (2012) show that indirect and defense costs can far exceed what attackers actually earn.

Part III preview

Stock-market event studies capture investors' expectations over a few days. Financial statements show the costs firms actually bear over time. The two can tell very different stories.

Case for discussion: Colonial Pipeline (2021)

- In May 2021, a ransomware attack led Colonial Pipeline to shut down the largest fuel pipeline on the U.S. East Coast for several days.
- The company paid a ransom of about $4.4 million; U.S. authorities later recovered part of it.
- The shutdown caused fuel shortages and panic buying far beyond the company itself.

Questions for discussion

1. Which of today's four reasons can you identify in this case?
2. Who bore the costs of the attack? Who could have prevented it?
3. Should paying a ransom be allowed? What externality does a payment create?

Summary

- Cybersecurity failures are often **economic failures**: the incentives to protect are weaker than the social value of protection.
- Four mechanisms: externalities, misaligned incentives, asymmetric information, and measurement.
- These mechanisms suggest economic remedies: liability, disclosure, insurance, and standards.

Next lecture: canonical models. How much should a firm invest in security, and what happens when its security depends on others?

Readings

- Anderson, R. (2001). Why information security is hard: An economic perspective. *Proceedings of the 17th Annual Computer Security Applications Conference (ACSAC)*.
- Anderson, R., and Moore, T. (2006). The economics of information security. *Science*, 314(5799), 610–613.
- Akerlof, G. (1970). The market for "lemons": Quality uncertainty and the market mechanism. *Quarterly Journal of Economics*, 84(3), 488–500.
- Anderson, R., et al. (2012). Measuring the cost of cybercrime. *Workshop on the Economics of Information Security (WEIS)*.